ZAP by Checkmarx Scanning Report

Sites: https://content-signature-2.cdn.mozilla.net http://localhost:3000

Generated on Sat, 6 Jun 2026 16:43:01

ZAP Version: 2.17.0

ZAP by Checkmarx

Summary of Alerts

Risk Level	Number of Alerts
High	0
Medium	5
Low	5
Informational	5

Insights

Level	Reason	Site	Description	Statistic
Low	Warning		ZAP errors logged - see the zap.log file for details	2
Low	Warning		ZAP warnings logged - see the zap.log file for details	5
Low	Exceeded High	http://localhost:3000	Percentage of responses with status code 4xx	50 %
Info	Informational	http://localhost:3000	Percentage of responses with status code 1xx	1 %
Info	Informational	http://localhost:3000	Percentage of responses with status code 2xx	59 %
Info	Informational	http://localhost:3000	Percentage of responses with status code 3xx	1 %
Info	Informational	http://localhost:3000	Percentage of responses with status code 5xx	2 %
Info	Informational	http://localhost:3000	Percentage of endpoints with content type application/javascript	7 %
Info	Informational	http://localhost:3000	Percentage of endpoints with content type application/json	6 %
Info	Informational	http://localhost:3000	Percentage of endpoints with content type application/octet-stream	3 %
Info	Informational	http://localhost:3000	Percentage of endpoints with content type image/jpeg	9 %
Info	Informational	http://localhost:3000	Percentage of endpoints with content type image/x-icon	1 %
Info	Informational	http://localhost:3000	Percentage of endpoints with content type text/css	1 %
Info	Informational	http://localhost:3000	Percentage of endpoints with content type text/html	65 %
Info	Informational	http://localhost:3000	Percentage of endpoints with content type text/markdown	2 %
Info	Informational	http://localhost:3000	Percentage of endpoints with content type text/plain	2 %
Info	Informational	http://localhost:3000	Percentage of endpoints with method GET	97 %
Info	Informational	http://localhost:3000	Percentage of endpoints with method POST	2 %
Info	Informational	http://localhost:3000	Count of total endpoints	128
Info	Exceeded Low	http://localhost:3000	Percentage of slow responses	18 %
Info	Informational	https://archive.mozilla.org	Percentage of responses with status code 2xx	100 %
Info	Informational	https://archive.mozilla.org	Percentage of slow responses	100 %
Info	Informational	https://content-signature-2.cdn.mozilla.net	Percentage of responses with status code 2xx	100 %
Info	Informational	https://content-signature-2.cdn.mozilla.net	Percentage of endpoints with content type binary/octet-stream	100 %
Info	Informational	https://content-signature-2.cdn.mozilla.net	Percentage of endpoints with method GET	100 %
Info	Informational	https://content-signature-2.cdn.mozilla.net	Count of total endpoints	1
Info	Informational	https://content-signature-2.cdn.mozilla.net	Percentage of slow responses	100 %

Summary of Sequences

For each step: result (Pass/Fail) - risk (of highest alert(s) for the step, if any).

Alerts

Name	Risk Level	Number of Instances
CSP: Failure to Define Directive with No Fallback	Medium	Systemic
CSP: style-src unsafe-inline	Medium	Systemic
Content Security Policy (CSP) Header Not Set	Medium	3
Missing Anti-clickjacking Header	Medium	3
Session ID in URL Rewrite	Medium	Systemic
Private IP Disclosure	Low	1
Server Leaks Version Information via "Server" HTTP Response Header Field	Low	1
Strict-Transport-Security Header Not Set	Low	1
Timestamp Disclosure - Unix	Low	Systemic
X-Content-Type-Options Header Missing	Low	6
Information Disclosure - Suspicious Comments	Informational	3
Modern Web Application	Informational	Systemic
Retrieved from Cache	Informational	1
Session Management Response Identified	Informational	1
User Agent Fuzzer	Informational	Systemic

Alert Detail

Medium	CSP: Failure to Define Directive with No Fallback
Description	The Content Security Policy fails to define one of the directives that has no fallback. Missing/excluding them is the same as allowing anything.
URL	http://localhost:3000/
Node Name	http://localhost:3000/
Method	GET
Parameter	Content-Security-Policy
Attack	
Evidence	default-src 'self';script-src 'self';style-src 'self' 'unsafe-inline';img-src 'self' data:;connect-src 'self';font-src 'self';object-src 'none';frame-src 'none'
Other Info	The directive(s): frame-ancestors, form-action is/are among the directives that do not fallback to default-src.
URL	http://localhost:3000/ftp
Node Name	http://localhost:3000/ftp
Method	GET
Parameter	Content-Security-Policy
Attack	
Evidence	default-src 'self';script-src 'self';style-src 'self' 'unsafe-inline';img-src 'self' data:;connect-src 'self';font-src 'self';object-src 'none';frame-src 'none'
Other Info	The directive(s): frame-ancestors, form-action is/are among the directives that do not fallback to default-src.
URL	http://localhost:3000/ftp/coupons_2013.md.bak
Node Name	http://localhost:3000/ftp/coupons_2013.md.bak
Method	GET
Parameter	Content-Security-Policy
Attack	
Evidence	default-src 'self';script-src 'self';style-src 'self' 'unsafe-inline';img-src 'self' data:;connect-src 'self';font-src 'self';object-src 'none';frame-src 'none'
Other Info	The directive(s): frame-ancestors, form-action is/are among the directives that do not fallback to default-src.
URL	http://localhost:3000/sitemap.xml
Node Name	http://localhost:3000/sitemap.xml
Method	GET
Parameter	Content-Security-Policy
Attack	
Evidence	default-src 'self';script-src 'self';style-src 'self' 'unsafe-inline';img-src 'self' data:;connect-src 'self';font-src 'self';object-src 'none';frame-src 'none'
Other Info	The directive(s): frame-ancestors, form-action is/are among the directives that do not fallback to default-src.
Instances	Systemic
Solution	Ensure that your web server, application server, load balancer, etc. is properly configured to set the Content-Security-Policy header.
Reference	https://www.w3.org/TR/CSP/ https://caniuse.com/#search=content+security+policy https://content-security-policy.com/ https://github.com/HtmlUnit/htmlunit-csp https://web.dev/articles/csp#resource-options
CWE Id	693
WASC Id	15
Plugin Id	10055

Medium	CSP: style-src unsafe-inline
Description	Content Security Policy (CSP) is an added layer of security that helps to detect and mitigate certain types of attacks. Including (but not limited to) Cross Site Scripting (XSS), and data injection attacks. These attacks are used for everything from data theft to site defacement or distribution of malware. CSP provides a set of standard HTTP headers that allow website owners to declare approved sources of content that browsers should be allowed to load on that page — covered types are JavaScript, CSS, HTML frames, fonts, images and embeddable objects such as Java applets, ActiveX, audio and video files.
URL	http://localhost:3000
Node Name	http://localhost:3000
Method	GET
Parameter	Content-Security-Policy
Attack	
Evidence	default-src 'self';script-src 'self';style-src 'self' 'unsafe-inline';img-src 'self' data:;connect-src 'self';font-src 'self';object-src 'none';frame-src 'none'
Other Info	style-src includes unsafe-inline.
URL	http://localhost:3000/
Node Name	http://localhost:3000/
Method	GET
Parameter	Content-Security-Policy
Attack	
Evidence	default-src 'self';script-src 'self';style-src 'self' 'unsafe-inline';img-src 'self' data:;connect-src 'self';font-src 'self';object-src 'none';frame-src 'none'
Other Info	style-src includes unsafe-inline.
URL	http://localhost:3000/ftp
Node Name	http://localhost:3000/ftp
Method	GET
Parameter	Content-Security-Policy
Attack	
Evidence	default-src 'self';script-src 'self';style-src 'self' 'unsafe-inline';img-src 'self' data:;connect-src 'self';font-src 'self';object-src 'none';frame-src 'none'
Other Info	style-src includes unsafe-inline.
URL	http://localhost:3000/ftp/coupons_2013.md.bak
Node Name	http://localhost:3000/ftp/coupons_2013.md.bak
Method	GET
Parameter	Content-Security-Policy
Attack	
Evidence	default-src 'self';script-src 'self';style-src 'self' 'unsafe-inline';img-src 'self' data:;connect-src 'self';font-src 'self';object-src 'none';frame-src 'none'
Other Info	style-src includes unsafe-inline.
URL	http://localhost:3000/sitemap.xml
Node Name	http://localhost:3000/sitemap.xml
Method	GET
Parameter	Content-Security-Policy
Attack	
Evidence	default-src 'self';script-src 'self';style-src 'self' 'unsafe-inline';img-src 'self' data:;connect-src 'self';font-src 'self';object-src 'none';frame-src 'none'
Other Info	style-src includes unsafe-inline.
Instances	Systemic
Solution	Ensure that your web server, application server, load balancer, etc. is properly configured to set the Content-Security-Policy header.
Reference	https://www.w3.org/TR/CSP/ https://caniuse.com/#search=content+security+policy https://content-security-policy.com/ https://github.com/HtmlUnit/htmlunit-csp https://web.dev/articles/csp#resource-options
CWE Id	693
WASC Id	15
Plugin Id	10055

Medium	Content Security Policy (CSP) Header Not Set
Description	Content Security Policy (CSP) is an added layer of security that helps to detect and mitigate certain types of attacks, including Cross Site Scripting (XSS) and data injection attacks. These attacks are used for everything from data theft to site defacement or distribution of malware. CSP provides a set of standard HTTP headers that allow website owners to declare approved sources of content that browsers should be allowed to load on that page — covered types are JavaScript, CSS, HTML frames, fonts, images and embeddable objects such as Java applets, ActiveX, audio and video files.
URL	http://localhost:3000/socket.io/?EIO=4&transport=polling&t=PwSQvJP&sid=Fz5k4dKBT5iRjq9SAAAA
Node Name	http://localhost:3000/socket.io/ (EIO,sid,t,transport)(40)
Method	POST
Parameter	
Attack	
Evidence	
Other Info	
URL	http://localhost:3000/socket.io/?EIO=4&transport=polling&t=PwSQvqs&sid=Fz5k4dKBT5iRjq9SAAAA
Node Name	http://localhost:3000/socket.io/ (EIO,sid,t,transport)(42["notification received","8d2072c6b0a4...)
Method	POST
Parameter	
Attack	
Evidence	
Other Info	
URL	http://localhost:3000/socket.io/?EIO=4&transport=polling&t=PwSQw1f&sid=Fz5k4dKBT5iRjq9SAAAA
Node Name	http://localhost:3000/socket.io/ (EIO,sid,t,transport)(42["notification received","9c297196ecf8...)
Method	POST
Parameter	
Attack	
Evidence	
Other Info	
Instances	3
Solution	Ensure that your web server, application server, load balancer, etc. is configured to set the Content-Security-Policy header.
Reference	https://developer.mozilla.org/en-US/docs/Web/HTTP/Guides/CSP https://cheatsheetseries.owasp.org/cheatsheets/Content_Security_Policy_Cheat_Sheet.html https://www.w3.org/TR/CSP/ https://w3c.github.io/webappsec-csp/ https://web.dev/articles/csp https://caniuse.com/#feat=contentsecuritypolicy https://content-security-policy.com/
CWE Id	693
WASC Id	15
Plugin Id	10038

Medium	Missing Anti-clickjacking Header
Description	The response does not protect against 'ClickJacking' attacks. It should include either Content-Security-Policy with 'frame-ancestors' directive or X-Frame-Options.
URL	http://localhost:3000/socket.io/?EIO=4&transport=polling&t=PwSQvJP&sid=Fz5k4dKBT5iRjq9SAAAA
Node Name	http://localhost:3000/socket.io/ (EIO,sid,t,transport)(40)
Method	POST
Parameter	x-frame-options
Attack	
Evidence	
Other Info	
URL	http://localhost:3000/socket.io/?EIO=4&transport=polling&t=PwSQvqs&sid=Fz5k4dKBT5iRjq9SAAAA
Node Name	http://localhost:3000/socket.io/ (EIO,sid,t,transport)(42["notification received","8d2072c6b0a4...)
Method	POST
Parameter	x-frame-options
Attack	
Evidence	
Other Info	
URL	http://localhost:3000/socket.io/?EIO=4&transport=polling&t=PwSQw1f&sid=Fz5k4dKBT5iRjq9SAAAA
Node Name	http://localhost:3000/socket.io/ (EIO,sid,t,transport)(42["notification received","9c297196ecf8...)
Method	POST
Parameter	x-frame-options
Attack	
Evidence	
Other Info	
Instances	3
Solution	Modern Web browsers support the Content-Security-Policy and X-Frame-Options HTTP headers. Ensure one of them is set on all web pages returned by your site/app. If you expect the page to be framed only by pages on your server (e.g. it's part of a FRAMESET) then you'll want to use SAMEORIGIN, otherwise if you never expect the page to be framed, you should use DENY. Alternatively consider implementing Content Security Policy's "frame-ancestors" directive.
Reference	https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/X-Frame-Options
CWE Id	1021
WASC Id	15
Plugin Id	10020

Medium	Session ID in URL Rewrite
Description	URL rewrite is used to track user session ID. The session ID may be disclosed via cross-site referer header. In addition, the session ID might be stored in browser history or server logs.
URL	http://localhost:3000/socket.io/?EIO=4&transport=polling&t=PwSQvJ-&sid=Fz5k4dKBT5iRjq9SAAAA
Node Name	http://localhost:3000/socket.io/ (EIO,sid,t,transport)
Method	GET
Parameter	sid
Attack	
Evidence	Fz5k4dKBT5iRjq9SAAAA
Other Info	
URL	http://localhost:3000/socket.io/?EIO=4&transport=websocket&sid=Fz5k4dKBT5iRjq9SAAAA
Node Name	http://localhost:3000/socket.io/ (EIO,sid,transport)
Method	GET
Parameter	sid
Attack	
Evidence	Fz5k4dKBT5iRjq9SAAAA
Other Info	
URL	http://localhost:3000/socket.io/?EIO=4&transport=polling&t=PwSQvJP&sid=Fz5k4dKBT5iRjq9SAAAA
Node Name	http://localhost:3000/socket.io/ (EIO,sid,t,transport)(40)
Method	POST
Parameter	sid
Attack	
Evidence	Fz5k4dKBT5iRjq9SAAAA
Other Info	
URL	http://localhost:3000/socket.io/?EIO=4&transport=polling&t=PwSQvqs&sid=Fz5k4dKBT5iRjq9SAAAA
Node Name	http://localhost:3000/socket.io/ (EIO,sid,t,transport)(42["notification received","8d2072c6b0a4...)
Method	POST
Parameter	sid
Attack	
Evidence	Fz5k4dKBT5iRjq9SAAAA
Other Info	
URL	http://localhost:3000/socket.io/?EIO=4&transport=polling&t=PwSQw1f&sid=Fz5k4dKBT5iRjq9SAAAA
Node Name	http://localhost:3000/socket.io/ (EIO,sid,t,transport)(42["notification received","9c297196ecf8...)
Method	POST
Parameter	sid
Attack	
Evidence	Fz5k4dKBT5iRjq9SAAAA
Other Info	
Instances	Systemic
Solution	For secure content, put session ID in a cookie. To be even more secure consider using a combination of cookie and URL rewrite.
Reference	https://seclists.org/webappsec/2002/q4/111
CWE Id	598
WASC Id	13
Plugin Id	3

Low	Private IP Disclosure
Description	A private IP (such as 10.x.x.x, 172.x.x.x, 192.168.x.x) or an Amazon EC2 private hostname (for example, ip-10-0-56-78) has been found in the HTTP response body. This information might be helpful for further attacks targeting internal systems.
URL	http://localhost:3000/rest/admin/application-configuration
Node Name	http://localhost:3000/rest/admin/application-configuration
Method	GET
Parameter	
Attack	
Evidence	192.168.99.100:3000
Other Info	192.168.99.100:3000 192.168.99.100:4200
Instances	1
Solution	Remove the private IP address from the HTTP response body. For comments, use JSP/ASP/PHP comment instead of HTML/JavaScript comment which can be seen by client browsers.
Reference	https://datatracker.ietf.org/doc/html/rfc1918
CWE Id	497
WASC Id	13
Plugin Id	2

Low	Server Leaks Version Information via "Server" HTTP Response Header Field
Description	The web/application server is leaking version information via the "Server" HTTP response header. Access to such information may facilitate attackers identifying other vulnerabilities your web/application server is subject to.
URL	https://content-signature-2.cdn.mozilla.net/g/chains/202402/remote-settings.content-signature.mozilla.org-2026-07-06-11-44-42.chain
Node Name	https://content-signature-2.cdn.mozilla.net/g/chains/202402/remote-settings.content-signature.mozilla.org-2026-07-06-11-44-42.chain
Method	GET
Parameter	
Attack	
Evidence	AmazonS3
Other Info	
Instances	1
Solution	Ensure that your web server, application server, load balancer, etc. is configured to suppress the "Server" header or provide generic details.
Reference	https://httpd.apache.org/docs/current/mod/core.html#servertokens https://learn.microsoft.com/en-us/previous-versions/msp-n-p/ff648552(v=pandp.10) https://www.troyhunt.com/shhh-dont-let-your-response-headers/
CWE Id	497
WASC Id	13
Plugin Id	10036

Low	Strict-Transport-Security Header Not Set
Description	HTTP Strict Transport Security (HSTS) is a web security policy mechanism whereby a web server declares that complying user agents (such as a web browser) are to interact with it using only secure HTTPS connections (i.e. HTTP layered over TLS/SSL). HSTS is an IETF standards track protocol and is specified in RFC 6797.
URL	https://content-signature-2.cdn.mozilla.net/g/chains/202402/remote-settings.content-signature.mozilla.org-2026-07-06-11-44-42.chain
Node Name	https://content-signature-2.cdn.mozilla.net/g/chains/202402/remote-settings.content-signature.mozilla.org-2026-07-06-11-44-42.chain
Method	GET
Parameter	
Attack	
Evidence	
Other Info	
Instances	1
Solution	Ensure that your web server, application server, load balancer, etc. is configured to enforce Strict-Transport-Security.
Reference	https://cheatsheetseries.owasp.org/cheatsheets/HTTP_Strict_Transport_Security_Cheat_Sheet.html https://owasp.org/www-community/Security_Headers https://en.wikipedia.org/wiki/HTTP_Strict_Transport_Security https://caniuse.com/stricttransportsecurity https://datatracker.ietf.org/doc/html/rfc6797
CWE Id	319
WASC Id	15
Plugin Id	10035

Low	Timestamp Disclosure - Unix
Description	A timestamp was disclosed by the application/web server. - Unix
URL	http://localhost:3000
Node Name	http://localhost:3000
Method	GET
Parameter	
Attack	
Evidence	1650485437
Other Info	1650485437, which evaluates to: 2022-04-21 01:10:37.
URL	http://localhost:3000
Node Name	http://localhost:3000
Method	GET
Parameter	
Attack	
Evidence	1981395349
Other Info	1981395349, which evaluates to: 2032-10-15 00:35:49.
URL	http://localhost:3000
Node Name	http://localhost:3000
Method	GET
Parameter	
Attack	
Evidence	2038834951
Other Info	2038834951, which evaluates to: 2034-08-10 20:02:31.
URL	http://localhost:3000/sitemap.xml
Node Name	http://localhost:3000/sitemap.xml
Method	GET
Parameter	
Attack	
Evidence	1650485437
Other Info	1650485437, which evaluates to: 2022-04-21 01:10:37.
URL	http://localhost:3000/sitemap.xml
Node Name	http://localhost:3000/sitemap.xml
Method	GET
Parameter	
Attack	
Evidence	2038834951
Other Info	2038834951, which evaluates to: 2034-08-10 20:02:31.
Instances	Systemic
Solution	Manually confirm that the timestamp data is not sensitive, and that the data cannot be aggregated to disclose exploitable patterns.
Reference	https://cwe.mitre.org/data/definitions/200.html
CWE Id	497
WASC Id	13
Plugin Id	10096

Low	X-Content-Type-Options Header Missing
Description	The Anti-MIME-Sniffing header X-Content-Type-Options was not set to 'nosniff'. This allows older versions of Internet Explorer and Chrome to perform MIME-sniffing on the response body, potentially causing the response body to be interpreted and displayed as a content type other than the declared content type. Current (early 2014) and legacy versions of Firefox will use the declared content type (if one is set), rather than performing MIME-sniffing.
URL	http://localhost:3000/socket.io/?EIO=4&transport=polling&t=PwSQvJ-&sid=Fz5k4dKBT5iRjq9SAAAA
Node Name	http://localhost:3000/socket.io/ (EIO,sid,t,transport)
Method	GET
Parameter	x-content-type-options
Attack	
Evidence	
Other Info	This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type. At "High" threshold this scan rule will not alert on client or server error responses.
URL	http://localhost:3000/socket.io/?EIO=4&transport=polling&t=PwSQuhB
Node Name	http://localhost:3000/socket.io/ (EIO,t,transport)
Method	GET
Parameter	x-content-type-options
Attack	
Evidence	
Other Info	This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type. At "High" threshold this scan rule will not alert on client or server error responses.
URL	https://content-signature-2.cdn.mozilla.net/g/chains/202402/remote-settings.content-signature.mozilla.org-2026-07-06-11-44-42.chain
Node Name	https://content-signature-2.cdn.mozilla.net/g/chains/202402/remote-settings.content-signature.mozilla.org-2026-07-06-11-44-42.chain
Method	GET
Parameter	x-content-type-options
Attack	
Evidence	
Other Info	This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type. At "High" threshold this scan rule will not alert on client or server error responses.
URL	http://localhost:3000/socket.io/?EIO=4&transport=polling&t=PwSQvJP&sid=Fz5k4dKBT5iRjq9SAAAA
Node Name	http://localhost:3000/socket.io/ (EIO,sid,t,transport)(40)
Method	POST
Parameter	x-content-type-options
Attack	
Evidence	
Other Info	This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type. At "High" threshold this scan rule will not alert on client or server error responses.
URL	http://localhost:3000/socket.io/?EIO=4&transport=polling&t=PwSQvqs&sid=Fz5k4dKBT5iRjq9SAAAA
Node Name	http://localhost:3000/socket.io/ (EIO,sid,t,transport)(42["notification received","8d2072c6b0a4...)
Method	POST
Parameter	x-content-type-options
Attack	
Evidence	
Other Info	This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type. At "High" threshold this scan rule will not alert on client or server error responses.
URL	http://localhost:3000/socket.io/?EIO=4&transport=polling&t=PwSQw1f&sid=Fz5k4dKBT5iRjq9SAAAA
Node Name	http://localhost:3000/socket.io/ (EIO,sid,t,transport)(42["notification received","9c297196ecf8...)
Method	POST
Parameter	x-content-type-options
Attack	
Evidence	
Other Info	This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type. At "High" threshold this scan rule will not alert on client or server error responses.
Instances	6
Solution	Ensure that the application/web server sets the Content-Type header appropriately, and that it sets the X-Content-Type-Options header to 'nosniff' for all web pages. If possible, ensure that the end user uses a standards-compliant and modern web browser that does not perform MIME-sniffing at all, or that can be directed by the web application/web server to not perform MIME-sniffing.
Reference	https://learn.microsoft.com/en-us/previous-versions/windows/internet-explorer/ie-developer/compatibility/gg622941(v=vs.85) https://owasp.org/www-community/Security_Headers
CWE Id	693
WASC Id	15
Plugin Id	10021

Informational	Information Disclosure - Suspicious Comments
Description	The response appears to contain suspicious comments which may help an attacker.
URL	http://localhost:3000/chunk-2ZPP2IXW.js
Node Name	http://localhost:3000/chunk-2ZPP2IXW.js
Method	GET
Parameter	
Attack	
Evidence	db
Other Info	The following pattern was used: \bDB\b and was detected in likely comment: "//angular.dev/best-practices/security#preventing-cross-site-scripting-xss",v=class extends Error{code;constructor(t,n){super(Ye(", see evidence field for the suspicious comment/snippet.
URL	http://localhost:3000/chunk-X436RDOR.js
Node Name	http://localhost:3000/chunk-X436RDOR.js
Method	GET
Parameter	
Attack	
Evidence	admin
Other Info	The following pattern was used: \bADMIN\b and was detected in likely comment: "//")}}`:t}else{let t=dh(i,(e,r)=>r===w?[Zi(i.children[w],!1)]:[`${r}:${Zi(e,!1)}`]);return Object.keys(i.children).length===1&&i", see evidence field for the suspicious comment/snippet.
URL	http://localhost:3000/main.js
Node Name	http://localhost:3000/main.js
Method	GET
Parameter	
Attack	
Evidence	query
Other Info	The following pattern was used: \bQUERY\b and was detected in likely comment: "//"+e.host),typeof t=="string"&&(t.charAt(0)==="/"&&(t.charAt(1)==="/"?t=e.protocol+t:t=e.host+t),/^(https?|wss?):\/\//.test(t)|", see evidence field for the suspicious comment/snippet.
Instances	3
Solution	Remove all comments that return information that may help an attacker and fix any underlying problems they refer to.
Reference	
CWE Id	615
WASC Id	13
Plugin Id	10027

Informational	Modern Web Application
Description	The application appears to be a modern web application. If you need to explore it automatically then the Ajax Spider may well be more effective than the standard one.
URL	http://localhost:3000
Node Name	http://localhost:3000
Method	GET
Parameter	
Attack	
Evidence	<script> window.addEventListener("load", function(){ window.cookieconsent.initialise({ "palette": { "popup": { "background": "var(--theme-primary)", "text": "var(--theme-text)" }, "button": { "background": "var(--theme-accent)", "text": "var(--theme-text)" } }, "theme": "classic", "position": "bottom-right", "content": { "message": "This website uses fruit cookies to ensure you get the juiciest tracking experience.", "dismiss": "Me want it!", "link": "But me wait!", "href": "https://www.youtube.com/watch?v=9PnbKL3wuH4" } })}); </script>
Other Info	No links have been found while there are scripts, which is an indication that this is a modern web application.
URL	http://localhost:3000/
Node Name	http://localhost:3000/
Method	GET
Parameter	
Attack	
Evidence	<script> window.addEventListener("load", function(){ window.cookieconsent.initialise({ "palette": { "popup": { "background": "var(--theme-primary)", "text": "var(--theme-text)" }, "button": { "background": "var(--theme-accent)", "text": "var(--theme-text)" } }, "theme": "classic", "position": "bottom-right", "content": { "message": "This website uses fruit cookies to ensure you get the juiciest tracking experience.", "dismiss": "Me want it!", "link": "But me wait!", "href": "https://www.youtube.com/watch?v=9PnbKL3wuH4" } })}); </script>
Other Info	No links have been found while there are scripts, which is an indication that this is a modern web application.
URL	http://localhost:3000/home/blazryn/juice-shop/build/routes/fileServer.js:43:13
Node Name	http://localhost:3000/home/blazryn/juice-shop/build/routes/fileServer.js:43:13
Method	GET
Parameter	
Attack	
Evidence	<script> window.addEventListener("load", function(){ window.cookieconsent.initialise({ "palette": { "popup": { "background": "var(--theme-primary)", "text": "var(--theme-text)" }, "button": { "background": "var(--theme-accent)", "text": "var(--theme-text)" } }, "theme": "classic", "position": "bottom-right", "content": { "message": "This website uses fruit cookies to ensure you get the juiciest tracking experience.", "dismiss": "Me want it!", "link": "But me wait!", "href": "https://www.youtube.com/watch?v=9PnbKL3wuH4" } })}); </script>
Other Info	No links have been found while there are scripts, which is an indication that this is a modern web application.
URL	http://localhost:3000/home/blazryn/juice-shop/build/routes/fileServer.js:59:18
Node Name	http://localhost:3000/home/blazryn/juice-shop/build/routes/fileServer.js:59:18
Method	GET
Parameter	
Attack	
Evidence	<script> window.addEventListener("load", function(){ window.cookieconsent.initialise({ "palette": { "popup": { "background": "var(--theme-primary)", "text": "var(--theme-text)" }, "button": { "background": "var(--theme-accent)", "text": "var(--theme-text)" } }, "theme": "classic", "position": "bottom-right", "content": { "message": "This website uses fruit cookies to ensure you get the juiciest tracking experience.", "dismiss": "Me want it!", "link": "But me wait!", "href": "https://www.youtube.com/watch?v=9PnbKL3wuH4" } })}); </script>
Other Info	No links have been found while there are scripts, which is an indication that this is a modern web application.
URL	http://localhost:3000/sitemap.xml
Node Name	http://localhost:3000/sitemap.xml
Method	GET
Parameter	
Attack	
Evidence	<script> window.addEventListener("load", function(){ window.cookieconsent.initialise({ "palette": { "popup": { "background": "var(--theme-primary)", "text": "var(--theme-text)" }, "button": { "background": "var(--theme-accent)", "text": "var(--theme-text)" } }, "theme": "classic", "position": "bottom-right", "content": { "message": "This website uses fruit cookies to ensure you get the juiciest tracking experience.", "dismiss": "Me want it!", "link": "But me wait!", "href": "https://www.youtube.com/watch?v=9PnbKL3wuH4" } })}); </script>
Other Info	No links have been found while there are scripts, which is an indication that this is a modern web application.
Instances	Systemic
Solution	This is an informational alert and so no changes are required.
Reference	
CWE Id	
WASC Id	
Plugin Id	10109

Informational	Retrieved from Cache
Description	The content was retrieved from a shared cache. If the response data is sensitive, personal or user-specific, this may result in sensitive information being leaked. In some cases, this may even result in a user gaining complete control of the session of another user, depending on the configuration of the caching components in use in their environment. This is primarily an issue where caching servers such as "proxy" caches are configured on the local network. This configuration is typically found in corporate or educational environments, for instance.
URL	https://content-signature-2.cdn.mozilla.net/g/chains/202402/remote-settings.content-signature.mozilla.org-2026-07-06-11-44-42.chain
Node Name	https://content-signature-2.cdn.mozilla.net/g/chains/202402/remote-settings.content-signature.mozilla.org-2026-07-06-11-44-42.chain
Method	GET
Parameter	
Attack	
Evidence	Age: 957
Other Info	The presence of the 'Age' header indicates that a HTTP/1.1 compliant caching server is in use.
Instances	1
Solution	Validate that the response does not contain sensitive, personal or user-specific information. If it does, consider the use of the following HTTP response headers, to limit, or prevent the content being stored and retrieved from the cache by another user: Cache-Control: no-cache, no-store, must-revalidate, private Pragma: no-cache Expires: 0 This configuration directs both HTTP 1.0 and HTTP 1.1 compliant caching servers to not store the response, and to not retrieve the response (without validation) from the cache, in response to a similar request.
Reference	https://datatracker.ietf.org/doc/html/rfc7234 https://datatracker.ietf.org/doc/html/rfc7231 https://www.rfc-editor.org/rfc/rfc9110.html
CWE Id	525
WASC Id	
Plugin Id	10050

Informational	Session Management Response Identified
Description	The given response has been identified as containing a session management token. The 'Other Info' field contains a set of header tokens that can be used in the Header Based Session Management Method. If the request is in a context which has a Session Management Method set to "Auto-Detect" then this rule will change the session management to use the tokens identified.
URL	http://localhost:3000/rest/continue-code
Node Name	http://localhost:3000/rest/continue-code
Method	GET
Parameter	continueCode
Attack	
Evidence	continueCode
Other Info	json:continueCode
Instances	1
Solution	This is an informational alert rather than a vulnerability and so there is nothing to fix.
Reference	https://www.zaproxy.org/docs/desktop/addons/authentication-helper/session-mgmt-id/
CWE Id	
WASC Id	
Plugin Id	10112

Informational	User Agent Fuzzer
Description	Check for differences in response based on fuzzed User Agent (eg. mobile sites, access as a Search Engine Crawler). Compares the response statuscode and the hashcode of the response body with the original response.
URL	http://localhost:3000/socket.io/?EIO=4&transport=polling&t=PwSR4ys&sid=htUA9E1swKHNWo4eAAAE
Node Name	http://localhost:3000/socket.io/ (EIO,sid,t,transport)
Method	GET
Parameter	Header User-Agent
Attack	Mozilla/4.0 (compatible; MSIE 8.0; Windows NT 6.1)
Evidence	
Other Info	
URL	http://localhost:3000/socket.io/?EIO=4&transport=websocket&sid=htUA9E1swKHNWo4eAAAE
Node Name	http://localhost:3000/socket.io/ (EIO,sid,transport)
Method	GET
Parameter	Header User-Agent
Attack	Mozilla/4.0 (compatible; MSIE 8.0; Windows NT 6.1)
Evidence	
Other Info	
URL	http://localhost:3000/socket.io/?EIO=4&transport=polling&t=PwSR2t4
Node Name	http://localhost:3000/socket.io/ (EIO,t,transport)
Method	GET
Parameter	Header User-Agent
Attack	Mozilla/4.0 (compatible; MSIE 7.0; Windows NT 6.0)
Evidence	
Other Info	
URL	http://localhost:3000/socket.io/?EIO=4&transport=polling&t=PwSR2t4
Node Name	http://localhost:3000/socket.io/ (EIO,t,transport)
Method	GET
Parameter	Header User-Agent
Attack	Mozilla/4.0 (compatible; MSIE 8.0; Windows NT 6.1)
Evidence	
Other Info	
URL	http://localhost:3000/socket.io/?EIO=4&transport=polling&t=PwSR3qV&sid=htUA9E1swKHNWo4eAAAE
Node Name	http://localhost:3000/socket.io/ (EIO,sid,t,transport)(40)
Method	POST
Parameter	Header User-Agent
Attack	Mozilla/4.0 (compatible; MSIE 8.0; Windows NT 6.1)
Evidence	
Other Info	
Instances	Systemic
Solution	
Reference	https://owasp.org/wstg
CWE Id	
WASC Id	
Plugin Id	10104

Sequence Details

With the associated active scan results.